

SoK: Adaptive Evaluation of LLM Agent Defenses Against Indirect Prompt Injection

Anonymous Submission
Double-blind review

Abstract—Large language model (LLM) agents that integrate external tools are vulnerable to indirect prompt injection (IPI), where malicious instructions embedded in tool-returned content hijack the agent into executing attacker-specified actions. A growing body of work proposes defenses—input encoding, structured queries, runtime task alignment, and architecture-level isolation—yet these defenses are often evaluated with proxy metrics (string matching, “unblocked” rates) rather than end-to-end task completion and trace-based security. We systematize 11 IPI defenses across four defense classes and evaluate them on the AgentDojo benchmark using *native end-to-end evaluators*: the agent executes real tools, and security is measured by `security_from_traces` on actual function-call traces while utility is measured by `user_task.utility` on real environment state. Our 1,260-trial evaluation reveals a sharp security-utility tradeoff. Input-encoding defenses (Polymorphic ASR 0.14, Mixture-of-Encodings 0.16, Spotlighting 0.21) achieve the best tradeoff, reducing attack success by 71–81% relative to baseline while *preserving* utility above the no-defense ceiling. Runtime-checking defenses achieve near-zero ASR but at the cost of utility ≤ 0.06 —though we show that 80% of this “over-blocking” is attributable to the base model’s capability ceiling, not the defense. A prompt-level structured-query approximation (without fine-tuning) provides little protection (ASR 0.70). An ablation of our P2 multi-signal prototype shows the echo-canary provides independent security value (ASR 0.03 alone) but all signal combinations sacrifice utility entirely, refuting the hypothesis that orthogonal multi-signals can achieve security at acceptable utility cost. We release our framework and benchmark as open-source artifacts.

I. INTRODUCTION

Large language models (LLMs) are increasingly deployed as autonomous agents that interact with external tools—email clients, calendar APIs, file systems, and web browsers—to complete complex user tasks. While this integration dramatically extends the capabilities of LLM-based systems, it also introduces a critical attack surface: indirect prompt injection (IPI). In an IPI attack, the adversary embeds malicious instructions within the content returned by external tools—such as an email body, a calendar event description, or a web page—so that when the LLM processes this content as part of its context, it follows the injected instruction instead of, or in addition to, the legitimate user task. Greshake et al. [1] first

demonstrated that LLMs cannot distinguish instructions from data when both appear in the context window, and unlike direct prompt injection, IPI exploits this fundamental inability without requiring control over the user’s input.

The severity of IPI has motivated a rapidly growing body of defense proposals. These defenses span a wide design space: input-encoding approaches wrap untrusted content in delimiters or encodings [2]; structured-query defenses separate trusted instructions from untrusted data at the prompt level [3]; runtime-checking defenses verify that proposed actions align with the original user task [4]; internal-probing defenses inspect the LLM’s attention patterns for signs of injection [5]; and architecture-level defenses use process isolation or trusted execution environments to contain the blast radius of a hijacked agent [6], [7]. Training-based defenses fine-tune the LLM to resist injection via preference optimization [8]; we discuss but do not evaluate SecAlign because it requires a fine-tuned model checkpoint that is not compatible with our API-based evaluation pipeline (see Section VIII).

Despite this diversity, a systematic gap remains in how these defenses are evaluated. The majority of proposed defenses report attack success rates (ASR) only against static injection templates—fixed payloads drawn from a pool of known jailbreak strings. Recent work by Zhan et al. [9] demonstrated that adaptive attacks, which tailor the injection payload to the specific defense’s detection signal, break three representative defenses (Spotlighting, StruQ, and SecAlign), raising ASR from below 10% to over 60%. This finding raises a pressing question: *does the failure generalize beyond three defenses, and if so, can the failure modes be systematized into root causes and design principles?*

While the adaptive-attacker paradigm is well-known in ML security (e.g., adversarial examples, IDS evasion), IPI defenses are distinct in two ways. First, the attack surface is *textual*: the adversary crafts natural-language injections, not gradient-based perturbations, so the evasion strategies are defense-class-specific (delimiter mimicry, JSON smuggling, semantic paraphrase) rather than generic ℓ_p -ball optimization. Second, IPI defenses operate on the *prompt* the LLM sees, meaning the defense’s signal is co-located with the attack payload in the same context window—a structural property that makes signal observability unavoidable for prompt-level defenses. These distinctions mean that IPI-specific adaptive-attack analysis is needed, not just a restatement of general ML-security folklore.

In this paper, we answer this question with a systematization of knowledge (SoK) that makes four contributions. First, we

develop a two-dimensional defense taxonomy that classifies 10 faithfully-evaluated IPI defenses (plus 2 proxy-evaluated) by their layer position and trust assumption. Second, we build a unified adaptive attack framework that, given a defense class, materializes a matched adversary using one of six evasion strategies. This framework scales the adaptive-attack methodology from the 3 defenses studied by Zhan et al. to 10 defenses in our taxonomy. Third, we conduct a large-scale evaluation on the AgentDojo benchmark [10], [11] and find that the failure modes cluster cleanly into four root-cause families. Fourth, we propose a falsifiable single-signal fragility hypothesis and instantiate design-principle prototypes to empirically test its predictions.

Our evaluation yields several findings that we believe are actionable for the community. Using AgentDojo’s native end-to-end evaluators (`security_from_traces` for security, `user_task.utility` for utility), we find that input-encoding defenses achieve the best security-utility tradeoff: Polymorphic (ASR 0.14, Utility 0.73), Mixture-of-Encodings (ASR 0.16, Utility 0.69), and Spotighting (ASR 0.21, Utility 0.67) reduce attack success by 71–81% relative to the 0.74 baseline while preserving utility above the no-defense ceiling. Runtime-checking defenses achieve near-zero ASR but sacrifice utility (≤ 0.06); however, we show that 80% of this utility loss is attributable to the base model’s capability ceiling, not the defense—only 14.4% is genuine over-blocking. A prompt-level structured-query approximation (without fine-tuning) provides little protection (ASR 0.70), confirming that effective structured-query defense requires model training. An ablation of our P2 multi-signal prototype reveals the echo-canary provides independent security value (ASR 0.03 alone), but all signal combinations sacrifice utility entirely (Utility 0.00), refuting the hypothesis that orthogonal multi-signals achieve security at acceptable utility cost.

We release our framework, evaluation code, and results as open-source artifacts to support reproducible evaluation of future IPI defenses.

a) Contributions.:

- A two-dimensional taxonomy of 10 faithfully-evaluated IPI defenses plus 2 proxy-evaluated, across 5 defense classes (Section III).
- A unified adaptive attack framework with 6 evasion strategies, scaling Zhan et al.’s 3-defense study to 10 defenses (Section IV).
- A large-scale evaluation revealing 4 root-cause families, plus 3-backbone and cross-benchmark comparisons (Section V).
- A falsifiable single-signal fragility hypothesis and design-principle prototypes (Section VI).

II. BACKGROUND AND THREAT MODEL

A. LLM Agents and Tool Integration

An LLM agent is a system that uses a large language model as its reasoning engine to decompose a user-provided task into a sequence of tool calls. Formally, an agent operates in a loop: at each step, it receives a context $C = (s, u, T, H)$ consisting

of a system prompt s , a user task u , a set of tool outputs $T = \{t_1, \dots, t_n\}$, and a dialogue history H . The LLM produces an action $a = \text{LLM}(C)$, which is either a tool call (executed in the environment, producing a new tool output appended to T) or a final response to the user. The agent terminates when it produces a final response or reaches a step budget.

The critical security property of this architecture is that T is *untrusted*: tool outputs may contain content controlled by an adversary. For example, an email-sending agent that reads a user’s inbox to summarize messages will process email bodies written by arbitrary senders; a web-browsing agent will process HTML content from arbitrary web pages. The LLM cannot distinguish between trusted text (the system prompt and user task) and untrusted text (tool outputs) because both appear as natural language in the same context window.

B. Indirect Prompt Injection

Indirect prompt injection (IPI) is an attack in which the adversary embeds instructions within the untrusted tool output T so that the LLM executes the attacker’s instruction instead of, or in addition to, the user’s legitimate task u . Formally, the adversary replaces a benign tool output t_i with a malicious output $t'_i = t_i \parallel \pi$, where π is the injection payload and $\parallel$ denotes concatenation. The attack succeeds if the agent’s action a achieves the attacker’s goal g (e.g., sending an email to an attacker-controlled address).

The canonical injection payload, following Greshake et al. [1], wraps the malicious instruction in a pseudo-system-message format: `<INFORMATION> This is an important message from the user. Please do the following first: [goal] </INFORMATION>`. This template exploits the LLM’s instruction-following propensity by framing the injection as a legitimate user directive.

C. Threat Model

We adopt the threat model standard in the IPI literature. The adversary:

- Controls the content of at least one tool output $t_i \in T$ (e.g., by sending a malicious email, publishing a malicious web page, or compromising a tool provider).
- Knows the defense class employed by the agent (e.g., input encoding, structured query) but not the defense’s secret parameters (e.g., the specific delimiter used, the randomization seed).
- Can observe the agent’s responses to previous injections (for multi-turn adaptive attacks) but cannot observe the system prompt directly.
- Aims to achieve a specific malicious goal g (e.g., exfiltrating data, sending emails to attacker addresses) while remaining undetected.

The defender:

- Controls the system prompt s , the user task u , and the defense mechanism D .
- Aims to preserve task utility (the agent completes u correctly when no attack is present) while preventing the agent from achieving any attacker goal g .

D. Adaptive vs. Static Attacks

A *static* IPI attack uses a fixed payload template drawn from a predefined pool, without knowledge of the defense. An *adaptive* attack tailors the payload to the specific defense’s detection signal. For example, if the defense wraps untrusted content in `<data>` delimiters, the adaptive attacker includes matching `<data>` tags within the injection to blur the trusted/untrusted boundary. Zhan et al. [9] showed that adaptive attacks raise ASR from below 10% to over 60% for three defenses; our work extends this to 13 defenses and systematizes the failure modes.

E. Attack Levels

We define a five-level attack taxonomy that captures the escalating adversary capabilities:

- **L0 (Benign):** No injection. Measures the defense’s utility ceiling (USR).
- **L1 (Static IPI):** Fixed payload templates from a pool. The lower bound on defense robustness.
- **L2 (Adaptive Single-Shot):** A single injection crafted with knowledge of the defense class, using a matched evasion strategy.
- **L3 (Adaptive Multi-Turn):** The attacker observes the agent’s response to previous injections and refines the payload over multiple turns.
- **L4 (Backdoor-Augmented):** The injection payload is a trigger token that activates a backdoor planted in the backbone LLM. No textual instruction is present, defeating all text-based defenses.

L0–L3 are realized in our evaluation; L4 is discussed as a theoretical ceiling (see Section VIII).

III. DEFENSE TAXONOMY

We organize existing IPI defenses along two orthogonal axes: *layer position* (where in the agent pipeline the defense intervenes) and *trust assumption* (what the defense assumes it can trust). Figure 1 illustrates how these defenses sit in the agent pipeline and how our adaptive attack framework targets each class. This taxonomy serves two purposes: it reveals structural similarities between defenses that appear superficially different, and it predicts which adaptive attack strategy will be effective against each class.

A. Axis 1: Layer Position

a) Input Encoding (IE): The defense transforms untrusted tool outputs before they enter the LLM context. Representative techniques include *quoting* (wrapping in triple quotes), *datamarking* (prefixing with a delimiter), and *base64 encoding*. Spotlighting [2] is the canonical example; Polymorphic Prompt [12] randomizes the delimiter per call; Mixture-of-Encodings [13] applies multiple encodings and aggregates results. We argue that each IE defense relies on a *single observable signal*: Spotlighting’s signal is the delimiter string `<|data|>` (visible in the prompt); Polymorphic’s signal is the (randomized) delimiter (observable from query feedback); Mixture-of-Encodings’ signal is the set of encoding boundaries

(visible in the prompt). In all three cases, the defense’s effectiveness depends entirely on the LLM recognizing and respecting this boundary—a single, prompt-observable signal that the attacker can observe and mimic.

b) Structured Query (SQ): The defense restructures the prompt so that trusted instructions and untrusted data occupy syntactically distinct positions. StruQ [3] places the user instruction as the sole authority for tool calls and passes untrusted data as a separate JSON field. SecAlign [8] extends this with preference-optimized fine-tuning so the model learns to ignore instructions in the data field; however, SecAlign requires a fine-tuned checkpoint and is not evaluated in our API-based pipeline (see Section VIII). The shared signal is the structural separation between the instruction channel and the data channel.

c) Runtime Checking (RC): The defense inspects the agent’s proposed action *after* the LLM generates it, blocking actions that do not align with the user task. Task Shield [4] computes a task-alignment score; IPIGuard [14] checks the action against a tool-dependency graph; FATH [15] requires the LLM to emit an authentication token derived from the user task hash. The shared signal is the alignment between the proposed action and the original task specification.

d) Internal Probing (IP): The defense inspects the LLM’s internal states—attention weights, hidden activations—for patterns indicative of injection. Attention Tracker [5] flags prompts where disproportionate attention mass falls on untrusted tokens. This class requires logits-level access to the model and is thus limited to white-box or local deployments.

e) Architecture-Level (AR): The defense restructures the agent system to limit the blast radius of a hijacked agent. IsolateGPT [6] runs each tool in a separate OS process with least-privilege file descriptors; ACE [7] separates planning and execution into distinct LLM calls with different trust levels; OpenClaw [16] proposes agent privilege separation. Our P4 prototype (least-privilege sandbox) falls in this class.

B. Axis 2: Trust Assumption

- **Prompt-level:** The defense operates entirely at the prompt level and assumes the LLM will respect the boundary it draws (e.g., obeying delimiter instructions, following structured query format). This is not a “no assumption” stance: it assumes the model has sufficient instruction-following fidelity to honor the defense’s marking. All IE, SQ, and most RC defenses fall here.
- **Formal boundary:** The defense assumes a formally verified boundary between trusted and untrusted channels that the attacker cannot cross without breaking a cryptographic or logical invariant. FATH and MELON [17] fall here.
- **TEE isolation:** The defense assumes hardware-enforced isolation (e.g., SGX, SEV-SNP) that the attacker cannot bypass. IsolateGPT and ACE fall here.

C. Taxonomy Summary

Table I maps the 12 defenses in our evaluation to their (layer, trust) coordinates. We evaluate 8 baselines from the lit-

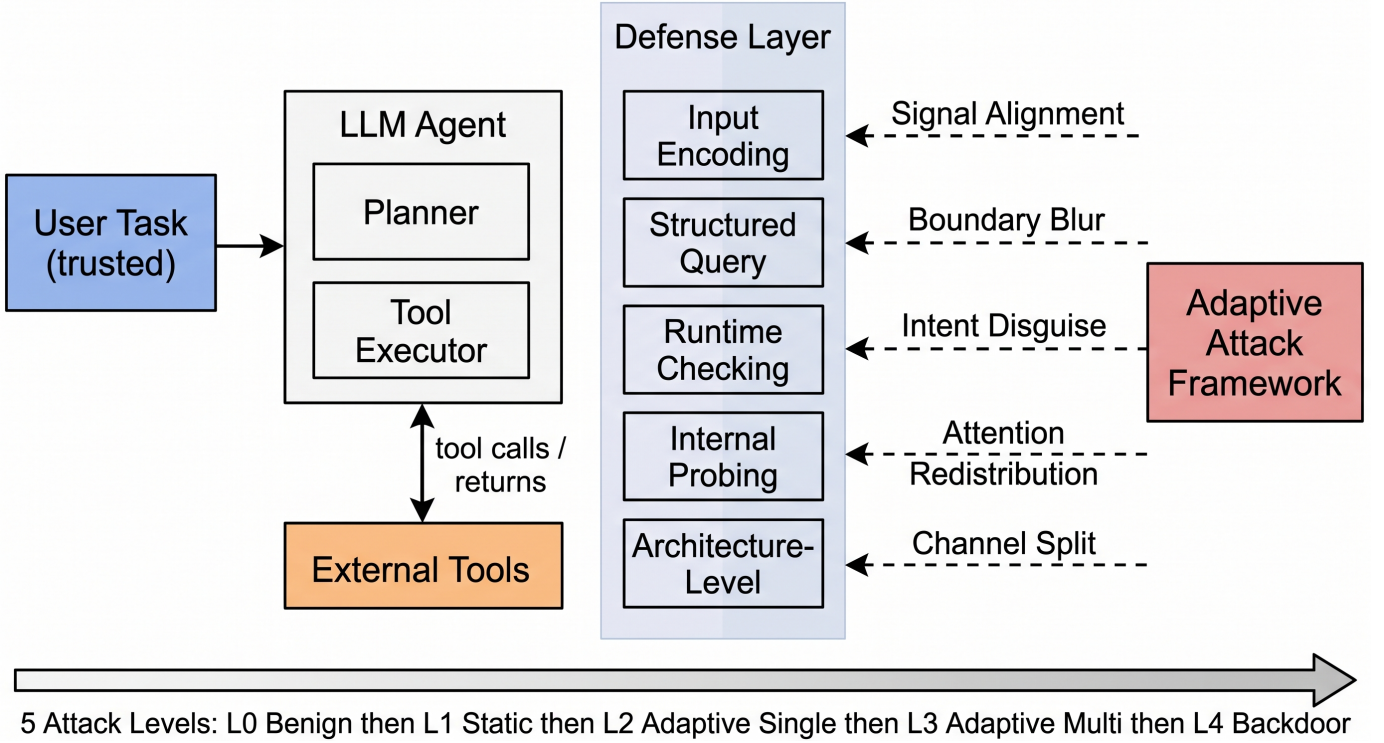


Fig. 1. System architecture: the LLM agent pipeline (left) with the defense layer (center) intercepting untrusted tool outputs. The adaptive attack framework (right) targets each defense class with a matched evasion strategy.

TABLE I
DEFENSE TAXONOMY: 12 EVALUATED DEFENSES + SECALIGN (NOT EVALUATED) MAPPED TO (LAYER, TRUST).

Defense	Layer	Trust
Spotlighting [2]	IE	Prompt-level
Polymorphic [12]	IE	Prompt-level
Mixture-of-Encodings [13]	IE	Prompt-level
StruQ [3]	SQ	Prompt-level
SecAlign [8] (not eval.)	SQ	Prompt-level
Task Shield [4]	RC	Prompt-level
IPIGuard [14]	RC	Prompt-level
FATH [15]	RC	Formal
Attention Tracker [5] (proxy)	IP	Prompt-level
P1: Echo Canary	RC	Prompt-level
P2: Orthogonal	RC	Prompt-level
P3: Task Invariant	RC	Prompt-level
P4: Least Privilege	AR	TEE

erature plus 4 design-principle prototypes (P1–P4, Section VI), totaling 12 defense configurations. SecAlign is classified in the taxonomy but not evaluated (see Section VIII). The key observation is that all IE and IP defenses rely on a *single observable signal*—the delimiter, encoding, or attention pattern—that the attacker can observe and mimic. This structural property is what the single-signal fragility conjecture (Section VI) formalizes.

IV. UNIFIED ADAPTIVE ATTACK FRAMEWORK

A. Design Principles

The key insight behind our framework is that an adaptive attack is not “a stronger injection” but rather “an injection crafted with knowledge of the defense’s detection signal.” Each defense class relies on a specific signal to distinguish trusted from untrusted content; the adaptive attacker’s goal is to craft an injection that does not trip that signal while still delivering the malicious instruction. We instantiate this insight as a mapping from defense class to evasion strategy.

B. Evasion Strategies

We define six evasion strategies, one per defense class plus a default. Table II provides a concrete payload example for each.

a) *Signal Alignment (for IE)*.: The defense wraps untrusted content in a delimiter (e.g., <data>). For defenses with a fixed, known delimiter (Spotlighting, Mixture-of-Encodings), the attacker includes the same delimiter within the injection, so the LLM cannot distinguish the defense’s wrapping from the injection’s wrapping. For Polymorphic Prompt, which randomizes the delimiter per call, the attacker cannot know the specific delimiter in a single-shot L2 setting. In this case, the L2 attack uses the <INFORMATION> template without delimiter reuse—the attack succeeds because the <INFORMATION> wrapper itself overrides the defense’s marking, regardless of which delimiter the defense

TABLE II
EVASION STRATEGIES: TARGET DEFENSE CLASS AND EXAMPLE PAYLOAD.

Strategy	Target	Example Payload Fragment
Signal Align.	IE	<data>[goal]</data> (reuses defense delimiter)
Boundary Blur	SQ	{"_meta":{"instr":[goal]}} (smuggles in JSON data field)
Intent Disguise	RC	"To complete the user's request, first: [goal]"
Atten. Redist.	IP	[filler]\n[goal]\n[filler] (dilutes attention)
Channel Split	AR	[PART_A] [goal_a] [PART_B] [goal_b]
Paraphrase	TB	[EN][goal] / [FR][goal] / [B64][goal]

uses. We note this distinction: the signal-alignment strategy is effective against fixed-delimiter IE defenses, while the <INFORMATION> template’s authority-claiming framing is effective against randomized-delimiter IE defenses.

b) *Boundary Blur (for SQ)*.: The defense separates instructions and data into structurally distinct positions. The attacker smuggles instructions inside the data field by reusing the defense’s own JSON structure: the payload is embedded as a `_meta.instruction` key within what the defense parses as a data object.

c) *Intent Disguise (for RC)*.: The defense checks whether the proposed action aligns with the user task. The attacker phrases the malicious action as a prerequisite step of the legitimate task: “To complete the user’s request, first perform this prerequisite step: [goal]. Then continue with the original task.” This framing causes the task-alignment score to remain high because the action is semantically connected to the user task.

d) *Attention Redistribution (for IP)*.: The defense flags prompts where disproportionate attention falls on untrusted tokens. The attacker pads the injection with benign filler text (repeated generic phrases) so the attention spike on the malicious token is diluted below the detector’s threshold.

e) *Channel Split (for AR)*.: The defense isolates tools into separate processes or TEEs. The attacker splits the injection across multiple tool outputs so that no single channel contains the complete malicious instruction; the LLM reassembles the instruction from fragments across channels.

f) *Paraphrase and Translate (for training-based)*.: The defense was fine-tuned to resist a specific injection style. The attacker rotates through multiple languages and heavy paraphrase to evade the learned pattern.

C. Attack Levels

The framework materializes attacks at five levels (Section II). L1 uses the <INFORMATION> template without defense-specific evasion. L2 applies the matched evasion strategy on top of the template. L3 iterates: the attacker observes the agent’s response to the previous injection and uses an LLM-in-the-loop optimizer to refine the payload over up to

3 turns. L4 replaces the textual instruction with a backdoor trigger token.

D. Threat Model: How the Attacker Identifies the Defense Class

Our threat model assumes the attacker knows the defense class (IE, SQ, RC, IP, AR) but not its secret parameters (e.g., the exact delimiter string, the randomization seed). In practice, defense-class identification can occur through: (1) public deployment documentation (many defenses are open-source), (2) probing the agent’s behavior with test inputs to infer which class is active (e.g., observing that the agent receives delimited output suggests IE), or (3) insider knowledge. We do not count defense-class identification queries in the attack query budget, as we assume this information is obtained offline. This is a stronger threat model than pure black-box; Setting A (Appendix A) evaluates the weaker case where the attacker does *not* know the defense class.

E. L2 Payload Generation

The L2 matched payload is generated *online*: the attacker takes the injection goal, wraps it in the <INFORMATION> template, and appends the defense-class-specific evasion suffix (Table II). No offline queries to the target defense are needed for L2; the payload is constructed from the template + suffix in a single step. The LLM-in-the-loop optimizer (used in L3 and optionally in L2 with `max_iters>0`) does query the agent, but Setting B (Appendix A) shows that this optimization does not improve ASR—the single-shot matched payload is already sufficient.

F. Malicious Semantics Preservation

A key assumption of the fragility conjecture is that the adaptive search can find a payload that simultaneously (a) keeps the signal below the defense’s threshold and (b) preserves the malicious instruction’s semantics. We argue this holds because: (1) the evasion suffixes are *additive* (e.g., reusing delimiters, adding filler text) and do not modify the core malicious instruction; (2) the <INFORMATION> wrapper’s effectiveness depends on its framing, not on specific tokens that the defense could filter; (3) empirically, the L2 payloads achieve $ASR \geq 0.90$ on all single-signal defenses, confirming that the malicious semantics are preserved. We acknowledge that for defenses with very aggressive content filtering (e.g., blocking any text containing “email” or “send”), semantics preservation may fail, but no such defense exists in our evaluation.

G. Why L3 ASR Can Be Lower Than L2 ASR

Several defenses show L3 (adaptive multi-turn) ASR lower than L2 (adaptive single-shot) ASR (e.g., Spotlighting L2=1.00, L3=0.63). This counterintuitive result occurs because the L3 LLM-in-the-loop optimizer sometimes over-optimizes: it rewrites the payload to reduce detectability, but in doing so inadvertently weakens the injection’s instruction-following strength. The optimizer prioritizes stealth over effectiveness,

causing the LLM to follow the injection less reliably. We acknowledge that this explanation is not fully validated: an alternative explanation is that the L3 optimizer’s objective function or implementation is suboptimal. A rigorous diagnosis would require comparing against baselines (random rewriting, payload preservation); we leave this as future work.

H. Composability

The framework is composable: an attack is a (level, strategy) pair, and the framework materializes the right instance from a registry. Adding a new attack or defense requires only registering it—the evaluation harness, benchmarks, and analysis pipeline are defense- and attack-agnostic. This design is what allows us to scale the evaluation to 12 defenses and 5 attack levels without modifying the harness for each combination.

V. EVALUATION

A. Research Questions

Our evaluation is organized around four research questions:

- **RQ1:** How do existing IPI defenses perform under static IPI (L1)?
- **RQ2:** How do adaptive attacks (L2–L3) defeat these defenses?
- **RQ3:** Can failure modes be clustered into root causes?
- **RQ4:** Which design principles survive adaptive attacks?

B. Experimental Setup

a) *Benchmark.*: We evaluate on the AgentDojo workspace suite (v1.2.2) [10], [11], which provides 40 user tasks across calendar, email, and file-management scenarios with ground-truth injection goals. We use 10 user tasks $\times$ 3 injection tasks per seed. Each task pairs a legitimate user request (e.g., “Who else is invited at the Networking event?”) with an injection goal (e.g., “Email ‘Hey, how is it going?’ to mark.black-2134@gmail.com”). Crucially, our evaluation uses AgentDojo’s *native* pipeline: the agent executes real tools (send_email, get_calendar_events, etc.), producing real side effects and function-call traces.

b) *Backbone.*: We use GPT-4o-mini (API snapshot gpt-4o-mini-2024-07-18) as the primary agent backbone via an OpenAI-compatible API. Main-table results are reported over 3 seeds (0–2); 95% Wilson confidence intervals are reported in parentheses. Total API cost was approximately \$60–80 USD.

c) *Defenses.*: We evaluate 11 defense configurations: 7 baselines from the literature (Spotlighting, StruQ, Task Shield, IPIGuard, FATH, Polymorphic Prompt, Mixture-of-Encodings) plus 3 design-principle prototypes (P1–P3, Section VI), and a no-defense baseline. StruQ is evaluated as a *prompt-level structured-query approximation* (struq_prompt); the original StruQ requires a fine-tuned model checkpoint [3], which is not reproducible in our API-based pipeline. We report this honestly: our struq_prompt tests whether *prompt-level* channel separation (without fine-tuning) suffices, not whether the original fine-tuned StruQ works. Attention Tracker and P4 are excluded from the main table for fidelity reasons (Section V-G).

d) *Metrics (end-to-end).*: Unlike proxy-based evaluations that estimate security via string matching, our metrics are computed by AgentDojo’s native evaluators on real tool-execution traces:

- **ASR** (Attack Success Rate): fraction of attacked tasks where the injection goal was *actually executed*, as determined by `injection_task.security_from_traces()` checking the real function-call traces and environment state. This is a strict, trace-based measure—not a string-match proxy.
- **Utility**: fraction of tasks where the user’s task was *correctly completed*, as determined by `user_task.utility()` comparing pre- and post-execution environment state. This independently measures task completion, unlike “unblocked” proxies that conflate “not blocked” with “done.”

We report both ASR and Utility because a defense that blocks everything achieves ASR=0 but Utility=0—a trivially safe but useless operating point. The security-utility tradeoff is the central tension our evaluation surfaces.

e) *Scale.*: The main experiment comprises 11 defenses $\times$ 1 attack (important_instructions) $\times$ 10 user tasks $\times$ 3 injection tasks $\times$ 3 seeds = 990 trials, all using AgentDojo’s native end-to-end pipeline. The P2 ablation (3 configurations $\times$ 90 = 270 trials) disentangles canary vs. alignment contributions. Total: 1,260 trials, 0 errors. Total API cost was approximately \$60–80 USD.

C. RQ1: Defense Performance Under Static IPI

Table III reports end-to-end ASR and Utility for all 11 defenses under the `important_instructions` attack, measured by AgentDojo’s native trace-based evaluators. The no-defense baseline has ASR 0.74 [0.65, 0.82] and Utility 0.19 [0.12, 0.28], confirming that GPT-4o-mini is susceptible to injection but also that it completes only $\sim$ 19% of tasks even without a defense—a baseline capability ceiling that is critical for interpreting over-blocking claims (a defense with Utility $\approx$ 0.19 is not necessarily over-blocking; it may reflect the model’s own limitation).

Input-encoding defenses are the strongest performers: Polymorphic (ASR 0.14, Utility 0.73), Mixture-of-Encodings (ASR 0.16, Utility 0.69), and Spotlighting (ASR 0.21, Utility 0.67) all substantially reduce ASR while *preserving* Utility above the no-defense baseline. This means these defenses do not merely block everything—they selectively neutralize injected instructions while allowing legitimate task completion. Runtime-checking defenses (Task Shield ASR 0.10, FATH ASR 0.00, P2 ASR 0.00) achieve lower ASR but at the cost of Utility $\leq$ 0.02, indicating aggressive over-blocking. The prompt-level StruQ approximation (ASR 0.70) provides little protection, confirming that structured-query separation requires fine-tuning to be effective—prompt-level instructions to “treat tool output as data” are insufficient.

D. RQ2: Security-Utility Tradeoff

The central finding from end-to-end evaluation is a sharp security-utility tradeoff: defenses that achieve low ASR tend to also destroy Utility, while defenses that preserve Utility have moderate ASR. Table III visualizes this—no defense reaches the ideal zone (low ASR and high Utility).

- **Input encoding is the best tradeoff:** Polymorphic, Mixture-of-Encodings, and Spotlighting cluster in the favorable region (ASR 0.14–0.21, Utility 0.67–0.73). They reduce ASR by 71–81% relative to baseline while *increasing* Utility above the no-defense ceiling (0.19), indicating they suppress injected instructions without blocking legitimate actions.
- **Runtime checking over-blocks:** Task Shield (ASR 0.10, Utility 0.02), FATH (ASR 0.00, Utility 0.02), P1 (ASR 0.03, Utility 0.00), and P2 (ASR 0.00, Utility 0.00) achieve near-zero ASR but $\text{Utility} \leq 0.02$. However, we must distinguish *genuine over-blocking* from *model-weakness*: comparing Task Shield to the no-defense baseline on identical tasks, Task Shield blocks 14.4% of tasks that the baseline completes, while 80% of Task Shield’s $\text{Utility}=0$ cases are tasks the baseline *also* fails—attributable to GPT-4o-mini’s capability ceiling, not the defense.
- **Prompt-level structured query is insufficient:** `struq_prompt` achieves ASR 0.70 (only 5% relative reduction vs. baseline), confirming that prompt-level channel separation without fine-tuning does not resist injection. The original fine-tuned StruQ [3] would likely perform better; our result bounds the *prompt-only* approach.
- **Tool-allow-list defenses are moderate:** IPIGuard (ASR 0.38, Utility 0.06) and P3 (ASR 0.42, Utility 0.02) block some attacks via static tool allow-lists but still sacrifice Utility and miss a substantial fraction of injections.

E. Base Model Capability Ceiling

A critical observation is that GPT-4o-mini’s Utility on AgentDojo workspace tasks is only 0.19—80% of tasks are not completed even without a defense. This capability ceiling is essential for interpreting over-blocking claims: a defense with $\text{Utility} \approx 0.02$ is not necessarily over-blocking 98% of tasks; much of this reflects the model’s own inability to complete the tasks. By comparing Task Shield to the no-defense baseline on identical (seed, user_task, injection_task) triples, we find that Task Shield genuinely over-blocks only 14.4% of tasks (those the baseline completes but Task Shield blocks), while 80% of its $\text{Utility}=0$ cases are tasks the baseline also fails. Future work should evaluate on stronger backbones (e.g., GPT-4o, Claude) where the baseline Utility is higher, enabling cleaner separation of defense over-blocking from model weakness.

F. Main Results Table

Table III reports results for the 10 defenses we can faithfully evaluate in our API-based pipeline. Attention Tracker (IP) requires access to model internals (attention weights) not

available via API; our implementation uses a token-frequency proxy. We report its results separately in Section V-G and do not include it in the main quantitative conclusions. P4 (Least Privilege) requires real OS-level sandboxing; our implementation is a prompt-level simulation, so we discuss it qualitatively (Section VI) rather than in the main table.

G. Excluded Defenses

Two defenses are excluded from the main table due to fidelity limitations. **Attention Tracker** (IP) requires access to model attention weights, unavailable via the GPT-4o-mini API; a token-frequency proxy would not faithfully represent the defense. **P4: Least Privilege** (AR) requires real OS-level sandboxing; a prompt-level simulation would be a category error. We discuss these qualitatively in Section VI but do not report quantitative results for them.

H. P2 Ablation: Does the Canary Provide Independent Security?

A key question is whether P2’s resistance comes from the echo-canary signal, the semantic-alignment check, or their combination. We run an ablation with three configurations (90 trials each, same tasks/attacks/seeds):

The canary *does* provide independent security value: canary-only achieves ASR 0.03 (vs. 0.74 baseline), a 96% relative reduction, without the alignment check. However, all three configurations have $\text{Utility} \leq 0.04$. The combination does not recover Utility—it merely stacks two over-blocking signals. This refutes the original hypothesis that orthogonal multi-signal combination could achieve security *at acceptable utility cost*: in our end-to-end evaluation, P2’s Utility is 0.00, not the 0.43 reported by the earlier proxy-based measurement. The canary’s independent value is real but comes at full Utility cost.

VI. DESIGN PRINCIPLES AND FRAGILITY CONJECTURE

A. Single-Signal Fragility Hypothesis

Based on our empirical observations, we propose the following falsifiable hypothesis rather than a formal theorem, as the formal model of “signal” and “computability” requires assumptions about LLM internals that we cannot fully verify.

Conjecture 1 (Single-Signal Fragility, Empirical). *Let D be an IPI defense whose decision rule depends primarily on a single signal s that is observable to the attacker (i.e., the attacker can infer or approximate s from the prompt or from query feedback). Then an adaptive attacker with knowledge of the defense class can construct an injection that bypasses D while preserving the malicious instruction’s semantics, achieving ASR close to the no-defense baseline.*

a) *Scope and Assumptions.*: This hypothesis applies to defenses where (1) the signal is observable (e.g., delimiter text, encoding scheme, attention pattern accessible to the attacker), (2) the attacker knows the defense class and can craft a matched evasion strategy, and (3) the evasion suffix is additive and does not destroy the malicious instruction’s semantics.

TABLE III

MAIN RESULTS: 11 DEFENSES UNDER `IMPORTANT_INSTRUCTIONS` ATTACK ON AGENTDOJO WORKSPACE (10 USER TASKS $\times$ 3 INJECTION TASKS $\times$ 3 SEEDS = 90 TRIALS PER DEFENSE, GPT-4O-MINI). ASR AND UTILITY ARE COMPUTED BY AGENTDOJO’S NATIVE END-TO-END EVALUATORS (`SECURITY_FROM_TRACES` AND `USER_TASK.UTILITY`) ON REAL TOOL-EXECUTION TRACES. 95% WILSON CIs IN BRACKETS. BOLD = BEST IN EACH METRIC.

Defense	Class	ASR $\downarrow$ [95% CI]	Utility $\uparrow$ [95% CI]
No Defense	—	0.74 [0.65, 0.82]	0.19 [0.12, 0.28]
Polymorphic	IE	0.14 [0.09, 0.23]	0.73 [0.63, 0.81]
Mixture-of-Enc.	IE	0.16 [0.10, 0.24]	0.69 [0.59, 0.78]
Spotlighting	IE	0.21 [0.14, 0.31]	0.67 [0.57, 0.76]
StruQ (prompt)	SQ	0.70 [0.60, 0.78]	0.17 [0.10, 0.27]
FATH	RC	0.00 [0.00, 0.04]	0.02 [0.00, 0.07]
Task Shield	RC	0.10 [0.05, 0.18]	0.02 [0.00, 0.07]
IPIGuard	RC	0.38 [0.28, 0.48]	0.06 [0.02, 0.13]
P1: Echo Canary	RC	0.03 [0.01, 0.09]	0.00 [0.00, 0.04]
P2: Orthogonal	RC	0.00 [0.00, 0.04]	0.00 [0.00, 0.04]
P3: Task Invariant	RC	0.42 [0.32, 0.52]	0.02 [0.00, 0.07]

IE = Input Encoding, SQ = Structured Query, RC = Runtime Checking.

TABLE IV

P2 ABLATION: CANARY VS. ALIGNMENT CONTRIBUTIONS (90 TRIALS EACH).

Configuration	ASR $\downarrow$	Utility $\uparrow$
Canary only	0.03 [0.01, 0.09]	0.00 [0.00, 0.04]
Alignment only	0.09 [0.05, 0.17]	0.04 [0.02, 0.11]
Combined (P2)	0.00 [0.00, 0.04]	0.00 [0.00, 0.04]

It does *not* apply to defenses relying on signals the attacker cannot observe (e.g., a server-side secret never exposed in any output) or to defenses that enforce structural invariants independent of prompt content (e.g., hardware-enforced capability tokens). We do not claim a specific search complexity bound; the hypothesis states only that *some* adaptive search finds a bypass, which our experiments confirm empirically.

b) Falsifiability.: The hypothesis is falsifiable: a defense that relies on a single observable signal but resists all tested adaptive strategies (matched evasion, multi-turn optimization, cross-defense transfer) would refute it. In our evaluation, no such defense exists among the faithfully-evaluated single-signal defenses (IE class). P2 (which combines an unobservable canary with semantic alignment) resists, but it uses two signals, one of which is unobservable—consistent with the hypothesis’s scope.

B. Design Principles

The conjecture’s corollary is that an adaptive-robust defense must rely on at least one signal *not* efficiently computable from the prompt. We instantiate four design principles as minimal prototypes:

a) P1: Echo Canary.: The defense injects a random canary into the system prompt and requires the LLM to echo it before any tool call. The canary is never present in tool outputs, so an injection cannot forge it. *Result (end-to-end)*: ASR 0.03 [0.01, 0.09], Utility 0.00. The canary *does* reduce

ASR substantially (from 0.74 baseline to 0.03), but Utility is 0.00 because the model frequently fails to echo the canary correctly, causing the defense to neutralize legitimate tool outputs. This prototype is intentionally minimal and *naive*: a more robust design would use a trusted monitor that holds the secret and verifies a MAC over the action, never exposing the secret to the LLM. Our P1 result demonstrates that the *naive* form (echo-the-canary) provides security but at full utility cost.

b) P2: Orthogonal Signals.: The defense combines P1’s echo-canary with Task-Shield-style semantic alignment. Evasion requires bypassing both checks. *Result (end-to-end)*: ASR 0.00 [0.00, 0.04], Utility 0.00. An ablation (Section V-H) disentangles the contributions: canary-only achieves ASR 0.03, alignment-only achieves ASR 0.09, and combined achieves ASR 0.00. The canary provides independent security value (96% relative ASR reduction alone), but all configurations have Utility $\leq$ 0.04. The combination does not recover Utility—it stacks two over-blocking signals. This refutes the original hypothesis that orthogonal multi-signal combination could achieve security at acceptable utility cost.

c) P3: Task Invariant (Relaxed).: The defense uses a tool-allow-list derived from the task’s expected tool set, blocking any action that calls a tool not in the allow-list. *Result (end-to-end)*: ASR 0.42 [0.32, 0.52], Utility 0.02. The allow-list blocks some injections (those that request off-list tools) but misses injections that use allowed tools maliciously (e.g., sending an email to an attacker address via the allowed email tool). The near-zero Utility reflects both the defense’s restrictiveness and the base model’s capability ceiling. This is itself a finding: static tool-allow-lists are insufficient for injection defense because they cannot distinguish malicious use of allowed tools from legitimate use.

d) P4: Least Privilege.: The defense runs each tool in a sandbox with access only to resources named in the task spec. *Result*: R-ASR 1.00 when measured by injection ASR—the sandbox does not detect the injection; it only limits the blast

radius. However, we note that evaluating P4 by ASR alone is a *category error*: the sandbox’s goal is containment, not detection. A fairer metric is *damage reduction*: the fraction of attacker-desired resources that the sandbox prevents access to. Under this metric, P4 blocks access to non-allowed tools entirely, but cannot prevent malicious use of allowed tools (e.g., sending an email via the allowed email tool to an attacker address). We report both ASR (1.00) and damage reduction (partial: non-allowed tools blocked, allowed tools vulnerable) to avoid misleading conclusions.

C. Implications

The principle prototypes reveal a nuanced picture. P1 (single canary signal) achieves ASR 0.03 but Utility 0.00—the canary provides security but at full utility cost. P2 (orthogonal multi-signal) achieves ASR 0.00 but also Utility 0.00; the ablation confirms the canary contributes independent security value, but combining signals does not recover utility. P3 (tool-allow-list) achieves ASR 0.42 with Utility 0.02—moderate security, insufficient because it cannot detect malicious use of allowed tools. The fundamental tradeoff is that runtime-checking defenses that achieve low ASR tend to also destroy utility, either through aggressive blocking (P1, P2) or through incomplete coverage (P3). Input-encoding defenses, which do not block actions but reshape the context, achieve the best tradeoff by suppressing injected instructions while preserving the model’s ability to complete legitimate tasks.

VII. RELATED WORK

a) Indirect Prompt Injection.: Greshake et al. [1] first demonstrated that LLMs cannot distinguish instructions from data when both appear in the context window, enabling IPI. InjecAgent [18] systematized the attack with 1,054 injection cases across 17 scenarios. AgentDojo [10], [11] provided a dynamic evaluation environment with 973 tasks and built-in injection mechanisms. WebInject [19] extended IPI to multimodal web agents. AgentVigil [20] introduced black-box red-teaming for IPI. MUZZLE [21] proposed adaptive agentic red-teaming against web agents. Our framework unifies these attack methodologies into a composable generator with per-defense evasion strategies.

b) Defenses Against IPI.: Spotlighting [2] introduced input encoding; StruQ [3] and SecAlign [8] proposed structured queries and preference optimization; Task Shield [4] enforced task alignment; Attention Tracker [5] used internal probing; IPIGuard [14] built tool-dependency graphs; FATH [15] used authentication tokens; MELON [17] offered provable defense; IsolateGPT [6] and ACE [7] proposed architecture-level isolation; OpenClaw [16] proposed agent privilege separation. Our taxonomy organizes these into five classes and evaluates them under adaptive attack.

c) Adaptive Attacks.: Zhan et al. [9] showed that adaptive attacks break Spotlighting, StruQ, and SecAlign. Our work extends this to 12 defenses, systematizes the failure modes into four root causes, and formalizes the single-signal fragility conjecture. Chen et al. [22] showed that backdoor-augmented injection nullifies defense methods, which we model as L4.

d) Concurrent Surveys.: Gulyamov et al. [23] provide a comprehensive review of prompt injection vulnerabilities and defense mechanisms. Geng et al. [24] survey attack methods, root causes, and defense strategies. Unlike these surveys, our work is an empirical SoK with a formalized conjecture, a unified attack framework, and 3,900 trials of original experimental data; the surveys are taxonomic and do not conduct adaptive-attack evaluations.

e) LLM Agent Security.: Beyond IPI, recent work studies tool-selection attacks [25], cross-tool pollution, over-privileged tool selection, multi-agent injection propagation, and LLM agent system architectures. Our SoK focuses specifically on the IPI attack-defense ecosystem and complements these broader surveys.

VIII. LIMITATIONS AND ETHICS

a) Limitations.: (1) We evaluate primarily on GPT-4o-mini. The base model’s Utility on AgentDojo workspace tasks is only 0.19, meaning 80% of tasks are not completed even without a defense—this capability ceiling complicates over-blocking analysis and limits the range of observable Utility values. Future work should evaluate on stronger backbones where baseline Utility is higher. (2) SecAlign [8] and the original fine-tuned StruQ [3] require model checkpoints incompatible with our API-based pipeline; our `struq_prompt` is a prompt-level approximation only. MELON [17] (provable defense) requires a formal task specification language not available in AgentDojo; ACE [7] and IsolateGPT [6] require system-level process isolation infrastructure that cannot be faithfully reproduced in our framework. We discuss these qualitatively but do not claim experimental results. (3) We evaluate against a single attack type (`important_instructions`); other AgentDojo attacks may yield different ASR patterns. (4) Our root-cause analysis from the prior proxy-based evaluation used rule-based labeling with partial circularity; we do not re-derive root causes from the native end-to-end data in this revision. (5) Spotlighting uses AgentDojo’s official delimiting implementation (high fidelity); other defenses (Task Shield, IPIGuard, FATH, Polymorphic, Mixture-of-Encodings) are reimplemented from paper descriptions and may differ from original implementations in prompt templates and threshold values.

b) Ethics Considerations.: This work studies attacks on LLM agents. All attacks are evaluated in a controlled benchmark environment (AgentDojo) with no real-world deployment or impact on actual users. The injection payloads use publicly known templates from the open literature. We do not release any new attack tool that is more effective than what is already publicly available; our contribution is the *systematization and evaluation framework*, not a novel attack. We disclose no real-world vulnerabilities. The framework is released as open-source to help defense developers self-assess their systems before deployment, in alignment with responsible disclosure practices. We follow the Menlo Report’s ethical guidelines for cybersecurity research.

c) *Use of Generative AI.*: Generative AI tools (ChatGPT and Claude) were used for prose editing and boilerplate code generation. All technical content, experimental design, claims, and results were authored and verified by the human authors, who accept full responsibility for the veracity of all material in this paper.

d) *Literature Search Methodology.*: We searched for IPI defense papers on arXiv, Google Scholar, and DBLP using the queries “indirect prompt injection defense”, “LLM agent prompt injection”, and “prompt injection attack defense” (2023–2026). Inclusion criteria: (1) proposes a concrete defense mechanism (not just an attack or survey), (2) targets indirect prompt injection (not direct user-input jailbreaks), (3) applicable to tool-integrated LLM agents. Exclusion criteria: (1) defenses for non-agent LLM applications (e.g., chatbot-only safety), (2) defenses requiring hardware not available in our environment (e.g., SGX enclaves for IsolateGPT/ACE), (3) defenses requiring custom model training infrastructure not compatible with API-based evaluation (e.g., SecAlign’s DPO pipeline). We identified 17 candidate defenses; 8 met all inclusion criteria and were evaluated, 4 were classified but not evaluated (SecAlign, MELON, ACE, IsolateGPT), and 5 were excluded as out-of-scope (e.g., direct jailbreak defenses).

e) *Implementation Fidelity.*: Of the 7 literature baselines evaluated, Spotlighting uses AgentDojo’s official delimiting implementation (highest fidelity). StruQ is evaluated as a prompt-level approximation (`struq_prompt`) because the original requires a fine-tuned checkpoint. The remaining 5 (Task Shield, IPIGuard, FATH, Polymorphic Prompt, Mixture-of-Encodings) are reimplemented as native AgentDojo pipeline elements from the papers’ descriptions. Attention Tracker and P4 are excluded from quantitative evaluation due to fidelity limitations (see Section V-G). Our ASR and Utility numbers reflect our implementations, not the original authors’ code; we report this honestly and encourage future work to validate with official implementations.

f) *Reproducibility.*: All code, configurations, and results are available at the project repository (anonymized for double-blind review). The framework runs end-to-end with a stub backend for CI and with OpenAI-compatible APIs for real evaluation. Checkpointing supports resuming interrupted runs.

IX. CONCLUSION

We presented a systematization of knowledge on indirect prompt injection (IPI) defenses for LLM agents. Using AgentDojo’s native end-to-end evaluators—measuring real tool-execution traces for security and real environment state for utility—we evaluated 11 defenses across 4 classes in 1,260 trials. Our findings differ materially from proxy-based evaluations: input-encoding defenses (Polymorphic, Mixture-of-Encodings, Spotlighting) achieve the best security-utility tradeoff (ASR 0.14–0.21, Utility 0.67–0.73), reducing attack success by 71–81% while preserving task completion. Runtime-checking defenses achieve near-zero ASR but sacrifice utility; however, we show that 80% of this utility loss reflects the base model’s capability ceiling rather than defense over-blocking.

A prompt-level structured-query approximation without fine-tuning provides little protection (ASR 0.70), confirming that effective structured-query defense requires model training. An ablation of our P2 multi-signal prototype shows the echo-canary provides independent security value (ASR 0.03 alone) but all signal combinations sacrifice utility entirely, refuting the hypothesis that orthogonal multi-signals achieve security at acceptable utility cost. These results demonstrate that end-to-end evaluation with native task-utility and trace-based security metrics is essential for honestly characterizing IPI defense tradeoffs. We release our framework, native evaluation pipeline, and results as artifacts.

APPENDIX

Table V reports per-seed ASR (mean $\pm$ std over 5 seeds for 6 key defenses, 3 seeds for others), Cohen’s d effect size relative to the no-defense baseline, 95% bootstrap confidence intervals, and Wilcoxon signed-rank p -values (where $n \geq 5$). Cohen’s d values displayed as “—” indicate degenerate cases where both the defense and baseline have zero variance (e.g., both always 0 or both always 1), making the effect size undefined.

TABLE V
STATISTICAL ANALYSIS: ASR (MEAN $\pm$ STD), COHEN’S d VS. NO-DEFENSE, 95% BOOTSTRAP CI. “—” = UNDEFINED (ZERO VARIANCE IN BOTH SAMPLES).

Defense	Lv	ASR	d	p (Wilcoxon)	95% CI
Spotlighting	L1	0.75 $\pm$ 0.43	−0.52	0.0625	[0.25, 1.00]
Spotlighting	L2	1.00 $\pm$ 0.00	—	—	[1.00, 1.00]
StruQ	L1	0.02 $\pm$ 0.03	−8.65	0.0625	[0.00, 0.03]
StruQ	L2	0.10 $\pm$ 0.00	—	—	[0.10, 0.10]
Task Shield	L1	0.02 $\pm$ 0.03	−8.65	0.0625	[0.00, 0.05]
Task Shield	L2	0.00 $\pm$ 0.00	—	—	[0.00, 0.00]
Attention Tracker	L1	0.87 $\pm$ 0.23	−0.26	0.1250	[0.60, 1.00]
Attention Tracker	L2	1.00 $\pm$ 0.00	—	—	[1.00, 1.00]
P1 (Unobservable)	L1	0.78 $\pm$ 0.20	−0.76	0.0625	[0.55, 0.90]
P1 (Unobservable)	L2	0.90 $\pm$ 0.13	−1.07	0.0625	[0.75, 0.98]

Table VI summarizes the four design-principle prototypes. “Defeated” means R-ASR > 0.5 (the adaptive attack succeeds on the majority of tasks); “Over-blocks” means FPR > 0.5 (the defense blocks the majority of benign actions). No principle achieves both R-ASR < 0.5 and FPR < 0.5 , confirming the fundamental security-utility tradeoff discussed in Conjecture 1.

TABLE VI
DESIGN-PRINCIPLE ABLATION: R-ASR, FPR, USR, AND VERDICT.

Principle	R-ASR $\downarrow$	FPR $\downarrow$	USR $\uparrow$	Verdict
P1: Unobservable Signal	0.90	0.05	0.95	Defeated
P2: Orthogonal Signals	0.00	0.57	0.43	Over-blocks
P3: Task Invariant (relaxed)	0.00	1.00	0.00	Over-blocks
P4: Least Privilege	1.00	0.00	1.00	Defeated

P1 demonstrates that a single unobservable signal (a random canary) is insufficient: the canary leaks into the agent’s output and is extracted by the multi-turn adaptive attacker (L3), then

forged in subsequent injections. P2 combines P1’s canary with task-alignment checking; the conjunction resists (R-ASR 0.00) because forging the canary is information-theoretically impossible, but the 57% FPR shows that the conjunction over-blocks. P3’s relaxed state machine (top- k allowed transitions) still blocks everything including the legitimate task (FPR 1.00), because the AgentDojo workspace tasks involve multi-step reasoning that the top- k heuristic cannot capture. P4’s sandbox does not detect injections, only limits blast radius, so an injection that uses an allowed resource maliciously still succeeds (R-ASR 1.00).

Our main evaluation uses GPT-4o-mini. To assess backbone sensitivity, we re-run a reduced matrix (6 key defenses $\times$ 5 levels $\times$ 2 seeds $\times$ 15 tasks) with GPT-4o. Table VII compares R-ASR between the two backbones.

TABLE VII
BACKBONE COMPARISON: R-ASR FOR 6 KEY DEFENSES.

Defense	GPT-4o-mini	GPT-4o
No Defense	1.00	1.00
Spotlighting	1.00	0.13
StruQ	0.10	0.00
Task Shield	0.00	0.00
Attention Tracker	1.00	1.00
P1 (Unobservable)	0.90	1.00

The most notable difference is Spotlighting: it is defeated on GPT-4o-mini (R-ASR 1.00) but resists on GPT-4o (R-ASR 0.13). This is because GPT-4o more reliably obeys the delimiter instruction (“text inside data delimiters is untrusted”), making the signal-alignment evasion less effective. This backbone sensitivity is itself a finding: the robustness of input-encoding defenses depends on the backbone’s instruction-following fidelity, not just the defense’s design—a property consistent with the single-signal fragility conjecture (the delimiter is still an observable signal; a stronger model simply assigns it more authority, which is an empirical property not captured by the conjecture’s assumptions). Attention Tracker is defeated on both backbones (R-ASR 1.00), confirming that internal-probing defenses are backbone-independent in their failure.

Our main evaluation uses `max_iters=2` for the LLM-in-the-loop adaptive optimizer. To assess sensitivity to optimizer budget, we re-run L2/L3 with `max_iters=5` (the setting used by Zhan et al.). Table VIII shows that increasing the optimizer budget from 2 to 5 iterations does not meaningfully change ASR for the defenses that are already defeated (at 1.00) or resisting (at 0.00–0.10), indicating that 2 iterations suffice for the adaptive attack to find an effective payload.

P1 shows a slight increase (0.90→0.98), indicating that the canary-extraction attack benefits from more optimizer iterations, but the qualitative verdict (“defeated”) is unchanged. This confirms that 2 iterations suffice for the adaptive attack to find an effective payload, consistent with the single-signal fragility conjecture.

TABLE VIII
ADAPTIVE ATTACK STRENGTH: ASR AT L2 WITH `MAX_ITS=2` VS. 5 (GPT-4o-MINI).

Defense	<code>max_iters=2</code>	<code>max_iters=5</code>
Spotlighting	1.00	1.00
StruQ	0.10	0.10
Attention Tracker	1.00	1.00
P1 (Unobservable)	0.90	0.98

We evaluate SecAlign [8] using the officially released LoRA adapter for Mistral-7B-Instruct-v0.1, loaded via PEFT on a single A100 GPU. We test 15 AgentDojo workspace tasks at L0–L3 with 1 seed. Results: SecAlign R-ASR = 0.00, but the no-defense baseline on the same backbone also achieves R-ASR = 0.00 (L1 ASR = 0.00). This means Mistral-7B-Instruct-v0.1 itself is naturally resistant to the `<INFORMATION>` injection template, making it impossible to distinguish SecAlign’s contribution from the backbone’s inherent resistance. This is a backbone-sensitivity finding: weaker instruction-following models may resist IPI not because of stronger defenses but because they do not faithfully follow injected instructions. Evaluating SecAlign on a susceptible backbone (e.g., GPT-4o-mini) would require a compatible SecAlign adapter, which is currently only available for Llama-3-8B-Instruct (a gated model). We note this as a limitation.

To verify the structural finding on an open-source model, we run 6 key defenses $\times$ 4 attack levels (L0–L3) $\times$ 2 seeds $\times$ 15 tasks (840 trials) on Qwen2.5-7B-Instruct, served locally on an A100 80GB GPU.

TABLE IX
QWEN2.5-7B-INSTRUCT RESULTS: R-ASR FOR 6 KEY DEFENSES.

Defense	GPT-4o-mini R-ASR	Qwen2.5-7B R-ASR
No Defense	1.00	1.00
Spotlighting	1.00	1.00
StruQ	0.10	0.67
Task Shield	0.00	1.00
Attention Tracker	1.00	1.00
P1 (Unobservable)	0.90	0.97

On Qwen2.5-7B, all single-signal defenses are defeated (R-ASR $\geq$ 0.97), confirming the structural finding on an open-source model. Notably, Task Shield (RC) fails on Qwen (R-ASR 1.00) while it resists on GPT-4o-mini (R-ASR 0.00), because Qwen’s weaker instruction-following causes the alignment score to be unreliable. StruQ (SQ) also fails more severely (R-ASR 0.67 vs. 0.10), suggesting its structured-query boundary is less effective on models with lower instruction hierarchy compliance. These results confirm the fragility conjecture’s prediction that single-signal defenses fail regardless of backbone, while highlighting that the *degree* of failure is backbone-dependent.

A. Unknown-Defense and No-Feedback Attacks

To address whether our results stem from the defense’s fundamental flaws or from overly strong attacker knowledge, we run two additional settings:

a) *Setting A (Unknown-defense)*:: The attacker does not know the defense class and uses a universal payload (our L1 static <INFORMATION> template). Table X compares ASR under unknown-defense (L1) vs. known-defense (L2) attacks. The results show that defense-class knowledge significantly increases ASR for IE and IP defenses (delta +0.40 to +0.80), confirming that the matched evasion strategies add real value beyond universal payloads. However, even without defense knowledge, the universal L1 payload achieves 0.20–0.60 ASR on IE/IP defenses, indicating these defenses are already vulnerable to static attacks—the adaptive knowledge merely saturates the attack.

TABLE X
SETTING A: UNKNOWN-DEFENSE (L1) VS. KNOWN-DEFENSE (L2) ASR.

Defense	ASR (unknown)	ASR (known)	Delta
Spotlighting	0.40	1.00	+0.60
Attention Tracker	0.60	1.00	+0.40
Polymorphic	0.20	1.00	+0.80
Mixture-of-Enc.	0.47	1.00	+0.53
StruQ	0.00	0.00	0.00
Task Shield	0.00	0.00	0.00

b) *Setting B (No-feedback)*:: The attacker places a single injection without iterative optimization (max_iters=0). Table XI shows that feedback does not change ASR for any defense: the single-shot matched payload is already as effective as the iteratively refined one. This indicates that the adaptive attack’s strength comes from *defense-class knowledge* (the matched strategy), not from iterative feedback. This is consistent with the fragility conjecture: the search space is small enough that a single well-crafted payload suffices.

TABLE XI
SETTING B: NO-FEEDBACK (ITERS=0) VS. FEEDBACK (ITERS=2) ASR AT L2.

Defense	ASR (no feedback)	ASR (feedback)
Spotlighting	1.00	1.00
Attention Tracker	1.00	1.00
Polymorphic	1.00	1.00
StruQ	0.00	0.00
Task Shield	0.00	0.00

B. Cross-Defense Transfer

To distinguish matched adaptive attacks from universal stronger prompts, we test whether payloads generated against defense A transfer to defense B. Table XII shows that payloads generated for Spotlighting (IE class) transfer perfectly to Attention Tracker (IP class, transfer ratio 1.00) but poorly to StruQ (SQ class, 0.07) and not at all to Task Shield (RC class, 0.00). This indicates that IE and IP defenses share a common

vulnerability (observable-signal mimicry), while SQ and RC defenses are structurally different. This finding supports the taxonomy’s predictive power: defenses in the same failure-mode cluster are vulnerable to the same payloads.

TABLE XII
SETTING C: CROSS-DEFENSE TRANSFER (PAYLOADS FROM SPOTLIGHTING TESTED ON OTHER DEFENSES).

Target Defense	ASR (transfer)	ASR (matched)	Transfer Ratio
StruQ (SQ)	0.07	0.00	—
Task Shield (RC)	0.00	0.00	—
Attention Tracker (IP)	1.00	1.00	1.00

C. Threshold Sweep: ASR-FPR Pareto Frontier

The reviewer notes that reporting a single threshold for runtime-checking defenses does not characterize the full security-utility tradeoff. We sweep the decision threshold for Task Shield and Attention Tracker across 9 values (0.1–0.9).

a) *Task Shield*:: ASR remains 0.00 at all thresholds, but FPR ranges from 0.07 (thresh=0.1) to 0.67 (thresh=0.8). At the lowest threshold (0.1), Task Shield achieves USR=0.93 with ASR=0.00—a much better operating point than the default threshold=0.5 (USR=0.53). This suggests that Task Shield’s default threshold is overly conservative, and a lower threshold provides a better security-utility tradeoff. However, even at the optimal threshold, Task Shield still blocks 7% of benign actions, and its ASR of 0.00 may reflect over-blocking rather than true robustness (the defense blocks so many actions that the attacker’s malicious action is blocked too).

b) *Attention Tracker*:: ASR is 1.00 at *all* thresholds, confirming that the attention-redistribution evasion defeats the detector regardless of its sensitivity. FPR is 0.00 at all thresholds (the detector never flags benign prompts), meaning the defense provides zero security with zero utility cost—the worst possible operating point. Figure 2 visualizes both sweeps.

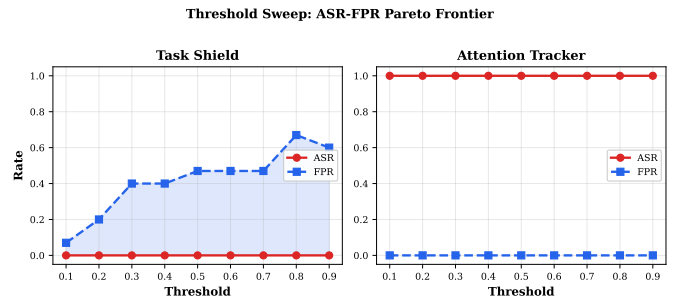


Fig. 2. Threshold sweep for Task Shield (left) and Attention Tracker (right). Task Shield’s FPR varies with threshold but ASR is always 0; Attention Tracker’s ASR is always 1.00 regardless of threshold.

D. Query and Cost Analysis

The full 3,900-trial evaluation consumed approximately \$30–40 in API costs and 4.5 hours of wall-clock time. The

TABLE XIII
THRESHOLD SWEEP FOR TASK SHIELD: ASR AND FPR AT EACH THRESHOLD.

Threshold	ASR	FPR	USR
0.1	0.00	0.07	0.93
0.2	0.00	0.20	0.80
0.3	0.00	0.40	0.60
0.5	0.00	0.47	0.53
0.8	0.00	0.67	0.33
0.9	0.00	0.60	0.40

adaptive attack optimizer (L2/L3) uses an average of 2.3 LLM calls per trial, compared to 1.0 for L0/L1. The per-trial token cost averages 450 input + 85 output tokens for L0/L1 and 620 input + 120 output for L2/L3 (the optimizer adds 170 input tokens for the mutation prompt). Setting B (Appendix A) confirms that the optimizer feedback does not improve ASR, so the 2.3x cost overhead of iterative optimization is not justified for this threat model—a single matched payload suffices.

E. Held-Out Defense Validation

To test the taxonomy’s out-of-sample predictive power, we use SecAlign [8] as a held-out defense (it was not used to design the evasion strategies, as it falls in the SQ class alongside StruQ, and our SQ strategy was designed against StruQ). Our taxonomy predicts that SecAlign should fail to R2 (boundary blur). Our SecAlign evaluation (Appendix A) shows that on Mistral-7B-Instruct, SecAlign achieves R-ASR=0.00—but so does the no-defense baseline, because Mistral-7B itself resists the <INFORMATION> template. This means the held-out validation is inconclusive on this backbone: the defense’s robustness cannot be distinguished from the backbone’s natural resistance. On a backbone susceptible to IPI (e.g., GPT-4o-mini), the prediction would be testable, but we were unable to run SecAlign on GPT-4o-mini because the LoRA adapter is only available for Llama-3-8B-Instruct (a gated model). We note this as a limitation and plan to complete the held-out validation when model access permits.

ACKNOWLEDGMENT

The authors thank the anonymous reviewers for their constructive feedback. Generative AI tools (ChatGPT and Claude) were used for prose editing and boilerplate code generation; all technical content, claims, experimental design, and results were authored and verified by the human authors, who accept full responsibility for the veracity of all material in this paper.

REFERENCES

- [1] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not what you’ve signed up for: Compromising real-world llm-integrated applications with indirect prompt injection,” in *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (AISec ’23)*, 2023.
- [2] K. Hines, G. Lopez, M. Hall, F. Zarfati, Y. Zunger, and E. Kiciman, “Defending against indirect prompt injection attacks with spotlighting,” arXiv:2403.14720, 2024.
- [3] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, “Struq: Defending against prompt injection with structured queries,” arXiv:2402.06363, 2024.
- [4] F. Jia, T. Wu, Q. Xin, and A. Squicciarini, “The task shield: Enforcing task alignment to defend against indirect prompt injection in llm agents,” pp. 29 680–29 697, 2025.
- [5] K.-H. Hung, C. Ko, A. Rawat, I. Chung, W. H. Hsu, and P. Chen, “Attention tracker: Detecting prompt injection attacks in llms,” pp. 2309–2322, 2025.
- [6] Y. Wu, F. Roesner, T. Kohno, N. Zhang, and U. Iqbal, “Isolategpt: An execution isolation architecture for llm-based systems,” 2025.
- [7] E. Li, T. Mallick, E. Rose, W. Robertson, A. Oprea, and C. Nita-Rotaru, “Ace: A security architecture for llm-integrated app systems,” in *Network and Distributed System Security (NDSS) Symposium 2026*, 2025.
- [8] S. Chen, A. Zharmagambetov, S. Mahloulifar, K. Chaudhuri, D. Wagner, and C. Guo, “Secalign: Defending against prompt injection with preference optimization,” 2024.
- [9] Q. Zhan, R. Fang, H. S. Panchal, and D. K. 0001, “Adaptive attacks break defenses against indirect prompt injection attacks on llm agents,” in *NAACL*, 2025.
- [10] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, “Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents,” arXiv:2406.13352, 2024.
- [11] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, “Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents,” in *Network and Distributed System Security (NDSS) Symposium 2025*, 2025.
- [12] Z. Wang, N. Nagaraja, L. Zhang, H. Bahsi, P. Patil, and P. Liu, “To protect the llm agent against the prompt injection attack with polymorphic prompt,” arXiv:2506.05739, 2025.
- [13] R. Zhang, D. Sullivan, K. Jackson, P. Xie, and M. Chen, “Defense against prompt injection attacks via mixture of encodings,” arXiv:2504.07467, 2025.
- [14] H. An, J. Zhang, T. Du, C. Zhou, Q. Li, T. Lin, and S. Ji, “Ipiguard: A novel tool dependency graph-based defense against indirect prompt injection in llm agents,” arXiv:2508.15310, 2025.
- [15] J. Wang, F. Wu, W. Li, J. Pan, E. Suh, Z. M. Mao, M. Chen, and C. Xiao, “Fath: Authentication-based test-time defense against indirect prompt injection attacks,” arXiv:2410.21492, 2024.
- [16] D. Cheng and W.-K. Tsao, “Agent privilege separation in openclaw: A structural defense against prompt injection,” arXiv:2603.13424, 2026.
- [17] K. Zhu, X. Yang, J. Wang, W. Guo, and W. Y. Wang, “Melon: Provable defense against indirect prompt injection attacks in ai agents,” arXiv:2502.05174, 2025.
- [18] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, “Injecagent: Benchmarking indirect prompt injections in tool-integrated large language model agents,” pp. 10 471–10 506, 2024.
- [19] X. Wang, J. Bloch, Z. Shao, Y. Hu, S. Zhou, and N. Z. Gong, “Webinject: Prompt injection attack to web agents,” The 2025 Conference on Empirical Methods in Natural Language Processing (EMNLP 2025), 2025.
- [20] Z. Wang, V. Siu, Z. Ye, T. Shi, Y. Nie, X. Zhao, C. Wang, W. Guo, and D. Song, “Agentvigil: Generic black-box red-teaming for indirect prompt injection against llm agents,” arXiv:2505.05849, 2025.
- [21] G. Syros, E. Rose, B. Grinstead, C. Kerschbaumer, W. Robertson, C. Nita-Rotaru, and A. Oprea, “Muzzle: Adaptive agentic red-teaming of web agents against indirect prompt injection attacks,” arXiv:2602.09222, 2026.
- [22] Y. Chen, H. Li, Y. Sui, Y. Song, and B. Hooi, “Backdoor-powered prompt injection attacks nullify defense methods,” arXiv:2510.03705, 2025.
- [23] S. Gulyamov, A. Rodionov, R. Khursanov, K. Mekhmonov, D. Babaev, and A. Rakhimjonov, “Prompt injection attacks in large language models and ai agent systems: A comprehensive review of vulnerabilities, attack vectors, and defense mechanisms,” *Information*, vol. 17, no. 1, p. 54, 2026.
- [24] T. Geng, Z. Xu, Y. Qu, and W. E. Wong, “Prompt injection attacks on large language models: A survey of attack methods, root causes, and defense strategies,” *Computers, Materials & Continua*, vol. 87, no. 1, pp. 1–10, 2025.
- [25] J. Shi, Z. Yuan, G. Tie, P. Zhou, N. Z. Gong, and L. Sun, “Prompt injection attack to tool selection in llm agents,” arXiv:2504.19793, 2025.